

Microsoft is pleased to announce the **February 2026 Revision (v2602)** of the security baseline package for **Windows Server 2025**! You can download the baseline package from the [Microsoft Security Compliance Toolkit](#), test the recommended configurations in your environment, and customize / implement them as appropriate.

## Summary of Changes in This Release

This release includes several changes made since the [Security baseline for Windows Server 2025, version 2506](#) to further assist in the security of enterprise customers along with better aligning with the latest capabilities and standards. The changes include what is now depicted in the table below.

| Security Policy                                                            | Change Summary                                                                                                                                               |
|----------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Configure the behavior of the sudo command                                 | Configured as <i>Enabled: Disabled</i> on both MS and DC                                                                                                     |
| Configure Validation of ROCA-vulnerable WHfB keys during authentication    | Configured as <i>Enabled: Block</i> on DC to block Windows Hello for Business (WHfB) keys that are vulnerable to the Return of Coppersmith's attack (ROCA)   |
| Disable Internet Explorer 11 Launch Via COM Automation                     | Configured as <i>Enabled</i> to prevent legacy scripts and applications from programmatically launching Internet Explorer 11 using COM automation interfaces |
| Do not apply the Mark of the Web tag to files copied from insecure sources | Configured as <i>Disabled</i> on both MS and DC                                                                                                              |
| Network security: Restrict NTLM: Audit Incoming NTLM Traffic               | Configured as <i>Enable auditing for all accounts</i> on both MS and DC                                                                                      |
| Network security: Restrict NTLM: Audit NTLM authentication in this domain  | Configured as <i>Enable all</i> on DC                                                                                                                        |
| Network security: Restrict NTLM: Outgoing NTLM traffic to remote servers   | Configured as <i>Audit all</i> on both MS and DC                                                                                                             |
| NTLM Auditing Enhancements                                                 | Already enabled by default to improve visibility into NTLM usage within your environment                                                                     |
| Prevent downloading of enclosures                                          | Remove from the baseline as it is not applicable for Windows Server 2025. It depends on IE – RSS feed                                                        |
| Printer: Configure RPC connection settings                                 | Enforce the default, <i>RPC over TCP with Authentication Enabled</i> , on both MS and DC                                                                     |
| Printer: Configure RPC listener settings                                   | Configure as <i>RPC over TCP   Kerberos</i> on MS                                                                                                            |
| Printer: Impersonate a client after authentication                         | Add <i>RESTRICTED SERVICES\PrintSpoolerService</i> to allow the                                                                                              |

|  |                                                                             |
|--|-----------------------------------------------------------------------------|
|  | Print Spooler's restricted service identity to impersonate clients securely |
|--|-----------------------------------------------------------------------------|

## Configure the behavior of the sudo command

Sudo for Windows can be used as a potential escalation of privilege vector when enabled in certain configurations. It may allow attackers or malicious insiders to run commands with elevated privileges, bypassing traditional UAC prompts. This is especially concerning in environments with Active Directory or domain controllers.

We recommend to configuring the policy **Configure the behavior of the sudo command** (System) as **Enabled** with the maximum allowed sudo mode as **Disabled** to prevent the sudo command from being used.

## Configure Validation of ROCA-vulnerable WHfB keys during authentication

To mitigate Windows Hello for Business (WHfB) keys that are vulnerable to the Return of Coppersmith's attack (ROCA), we recommend enabling the setting **Configure Validation of ROCA-vulnerable WHfB keys during authentication** (System\Security Account Manager) in a **Block mode** in **domain controllers**. To ensure there are no incompatible devices/orphaned/vulnerable keys in use that will break when blocked, please see [Using WHfBTools PowerShell module for cleaning up orphaned Windows Hello for Business Keys - Microsoft Support](#). Note: A reboot is not required for changes to this setting to take effect.

## Disable Internet Explorer 11 Launch Via COM Automation

Similar to the Windows 11 version 25H2 security baseline, we recommend disabling **Internet Explorer 11 Launch Via COM Automation** (Windows Components\Internet Explorer) to prevent legacy scripts and applications from programmatically launching Internet Explorer 11 using COM automation interfaces such as `CreateObject("InternetExplorer.Application")`. Allowing such behavior poses a significant risk by exposing systems to the legacy MSHTML and ActiveX components, which are vulnerable to exploitation.

## Do not apply the Mark of the Web tag to files copied from insecure sources

We have included the setting **Do not apply the Mark of the Web tag to files copied from insecure sources** (Windows Components\File Explorer) configured as **Disabled**, which is consistent with Windows 11 security baseline. When this configuration is set to Disabled, Windows applies the Mark of the Web (MotW) tag to files copied from locations classified as Internet or other untrusted zones. This tag helps enforce additional protections

such as SmartScreen checks and Office macro blocking, reducing the risk of malicious content execution.

## NTLM Auditing

As part of our ongoing effort to help customers transition away from NTLM and adopt Kerberos for a more secure environment, we introduce new recommendations to strengthen monitoring and prepare for future NTLM restrictions on Windows Server 2025.

- Configure **Network security: Restrict NTLM: Audit Incoming NTLM Traffic** (Security Options) to **Enable auditing for all accounts** on both **member servers** and **domain controllers**. When enabled, the server logs events for all NTLM authentication requests that would be blocked once incoming NTLM traffic restrictions are enforced.
- Configure **Network security: Restrict NTLM: Audit NTLM authentication in this domain** (Security Options) to **Enable all** on **domain controllers**. This setting logs NTLM pass-through authentication requests from servers and accounts that would be denied when NTLM authentication restrictions are applied at the domain level.
- Configure **Outgoing NTLM traffic to remote servers** (Security Options) to **Audit all** on both **member servers** and **domain controllers** to log an event for each NTLM authentication request sent to a remote server, helping identify servers that still receive NTLM traffic.

In addition, there are two new NTLM auditing capabilities enabled by default that were recently introduced in Windows Server 2025 and Windows 11 version 25H2. These enhancements provide detailed audit logs to help security teams monitor and investigate authentication activity, identify insecure practices, and prepare for future NTLM restrictions. Since these auditing improvements are enabled by default, no additional configuration is required, and thus the baseline does not explicitly enforce them. For more details, see [Overview of NTLM auditing enhancements in Windows 11 and Windows Server 2025](#).

## Prevent Downloading of Enclosures

The policy **Prevent downloading of enclosures** (Windows Components\RSS Feeds) has been removed from the Windows Server 2025 security baseline. This setting is not applicable to Windows Server 2025 because it depends on Internet Explorer functionality for RSS feeds.

## Printer security enhancements

There are two new policies in Windows Server 2025 designed to significantly improve security posture of printers:

- **Require IPPS for IPP printers** (Printers)
- **Set TLS/SSL security policy for IPP printers** (Printers)

Enabling these policies may cause operational challenges in environments that still rely on IPP or use self-signed or locally issued certificates. For this reason, these policies are not enforced in the Windows Server 2025 security baseline. However, we do recommend customers transition out of IPP or self-signed certificates and restricting them for a more secure environment.

In addition, there are some changes to printer security

- Added **RESTRICTED SERVICES\PrintSpoolerService** to the **Impersonate a client after authentication** (User Rights Assignments) policy for both **member servers** and **domain controllers**, consistent with [security baseline for Windows 11 version 25H2](#).
- Enforced the default setting for **Configure RPC connection settings** (Printers) to always use **RPC over TCP** with **Authentication Enabled** on both **member servers** and **domain controllers**. This prevents misconfiguration that could introduce security risks.
- Raised the security bar of the policy **Configure RPC listener settings** (Printers) from Negotiate (default) to **Kerberos** on **member servers**. This change encourages customers to move away from NTLM and adopt Kerberos for a more secure environment.

## Secure Boot certificate update

To help organizations deploy, manage, and monitor the Secure Boot certificate update, Windows includes several policy settings under `Administrative Templates\Windows Components\Secure Boot`. These settings are deployment controls and aids.

- **Enable Secure Boot Certificate Deployment** allows an organization to explicitly initiate certificate deployment on a device. When enabled, Windows begins the Secure Boot certificate update process the next time the Secure Boot task runs. This setting does not override firmware compatibility checks or force updates onto unsupported devices.

- **Automatic Certificate Deployment via Updates** controls whether Secure Boot certificate updates are applied automatically through monthly Windows security and non-security updates. By default, devices that Microsoft has identified as capable of safely applying the updates will receive and apply them automatically as part of cumulative servicing. If this setting is disabled, automatic deployment is blocked and certificate updates must be initiated through other supported deployment methods.
- **Certificate Deployment via Controlled Feature Rollout** allows organizations to opt devices into a Microsoft-managed Controlled Feature Rollout for Secure Boot certificate updates. When enabled, Microsoft assists with coordinating deployment across enrolled devices to reduce risk during rollout. Devices participating in a Controlled Feature Rollout must have diagnostic data enabled. Devices that are not enrolled will not participate.

Secure Boot certificate updates depend on device firmware support. Some devices have known firmware limitations that can prevent updates from being applied safely. Organizations should test representative hardware, monitor Secure Boot event logs, and consult the deployment guidance at <https://aka.ms/GetSecureBoot> for detailed recommendations and troubleshooting information.

## SMB Server hardening feature

SMB Server has been susceptible to relay attacks (e.g., [CVE-2025-55234](#)), and Microsoft has released multiple features to protect against the relay attacks including

- **SMB Server signing**, which can be enabled with the setting of **Microsoft network server: Digitally sign communications (always)** (Security Option)
- **SMB Server extended protection for authentication (EPA)**, which can be enabled with the setting of **Microsoft network server: Server SPN target name validation level** (Security Option)

To further support customers to adopt these SMB Server hardening features, in the [September 2025 Security Updates](#), Microsoft has released support for **Audit events**, across all supported in-market platforms, to audit SMB client compatibility for SMB Server signing as well as SMB Server EPA. These audit capabilities can be controlled via the two policies located at `Network\Lanman Server`

- **Audit client does not support signing**
- **Audit SMB client SPN support**

This allows you to identify any potential device or software incompatibility issues before deploying the hardening measures that are already supported by SMB Server.

Our recommendation is

- For domain controllers, the SMB signing is already enabled by default so there is no action needed for hardening purposes.
- For member servers, first enabling the two new audit features to assess the environment and then decide whether SMB Server Signing or EPA should be used to mitigate the attack vector.

Please let us know your thoughts by commenting on this post or through the [Security Baseline Community](#).